

WEB APPLICATION SECURITY TESTING REPORT

Task 3 – Web Application Security

Submitted By

Akshitha Bodanapu

Internship

Cybersecurity & Ethical Hacking Internship – ApexPlanet

Introduction

Web Application Security is the practice of protecting websites and web applications from cyber threats and vulnerabilities. This task focuses on understanding common OWASP Top 10 vulnerabilities and their mitigation techniques.

The vulnerabilities studied in this task include SQL Injection, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), File Inclusion, Burp Suite Request Analysis, and Security Headers Analysis.

1. SQL Injection

Description

SQL Injection is a vulnerability that occurs when user input is inserted directly into SQL queries without proper validation.

Example Payload

1' OR '1'='1

Impact

- Unauthorized access to database records
- Authentication bypass

- Data leakage

Mitigation

- Prepared Statements
 - Parameterized Queries
 - Input Validation
 - Stored Procedures
-

2. Cross-Site Scripting (XSS)

Description

Cross-Site Scripting (XSS) allows attackers to inject malicious JavaScript code into web pages viewed by users.

Example Payload

Impact

- Session Hijacking
- Cookie Theft
- User Impersonation

Mitigation

- Input Sanitization
 - Output Encoding
 - Content Security Policy (CSP)
-

3. Cross-Site Request Forgery (CSRF)

Description

CSRF attacks force authenticated users to perform actions without their consent.

Impact

- Unauthorized password changes
- Unauthorized account actions
- Security breaches

Mitigation

- CSRF Tokens
 - SameSite Cookies
 - User Verification
-

4. File Inclusion Vulnerability

Description

File Inclusion vulnerabilities allow attackers to access sensitive files on a server.

Example Payload

```
../../../../etc/passwd
```

Impact

- Information Disclosure
- Access to Sensitive Files
- System Compromise

Mitigation

- Restrict File Access
 - Whitelist Allowed Files
 - Validate User Input
-

5. Burp Suite Request Analysis

Description

Burp Suite is a web security testing tool used to intercept and analyze HTTP requests and responses.

Features

- Request Interception
- Traffic Analysis
- Vulnerability Testing
- Security Assessment

Mitigation

- HTTPS Implementation
 - Secure Session Management
 - Server-Side Validation
-

6. Security Headers Analysis

Description

Security Headers provide additional protection against common web attacks.

Important Security Headers

- Content-Security-Policy (CSP)
- X-Frame-Options
- Strict-Transport-Security (HSTS)
- X-Content-Type-Options

Benefits

- Prevents Clickjacking
 - Prevents MIME-Type Attacks
 - Enhances Browser Security
-

Conclusion

This task provided practical knowledge of common web application vulnerabilities and their mitigation techniques. Understanding these vulnerabilities helps developers and security professionals build secure web applications and reduce cyber security risks.

The study emphasized the importance of secure coding practices, input validation, security headers, and proper security testing methodologies.

References

- OWASP Top 10
- Burp Suite Documentation
- Web Application Security Concepts
- Security Headers Best Practices

